

VenQore

Routing & Permission Surgical Fix

Closes the three wounds that let store owners bleed into the Platform HQ

Wound 1	400+ legacy routes have no store context — anyone can drift to platform
Wound 2	CheckPermissions.php grants God Mode to anyone with role 'owner'
Wound 3	Frontend shows Platform HQ links when store prop is null
Result	Store owners see platform dashboards, reports, and hidden admin URLs
Fix Time	1 focused day — 10 steps executed in order

What Is Actually Broken — Plain English

Before reading the fix, read this so you understand exactly what went wrong and why the fix is structured the way it is.

Zone	Where it lives	What should happen	What is happening now
Platform HQ	/VenQore/...	Only you can see this. 404 for everyone else.	Store owners can reach it by accident
Store World	/s/{store-slug}/...	Each store owner sees only their own store	Working correctly when routes are in this zone
Legacy Black Hole	/reports, /inventory, /pos...	These should NOT exist as bare URLs anymore	400+ routes still live here with no store context

Store owner clicks 'Admin Panel' → Frontend has no store prop (legacy thinks: no store = must be platform admin → Shows platform HQ links – (legacy, no tenant) → System panics → redirects to /VenQore-login → F customer.

1

Fix CheckPermissions.php

Remove the God Mode bypass that lets 'owner' role through everything

One line in CheckPermissions.php currently says: if the user's role is 'owner' or 'admin' then they can access everything. This was fine when one shop installed the software on their own server. But if a user's role is 'owner' and they land on a platform route gets silently waved through the firewall.

Remove This (The Bug):

```
// REMOVE THIS COMPLETELY – this is the line causing God Mode leak
if ($user->role === 'owner' || $user->role === 'admin') {
    return $next($request); // ← This lets ANYONE with 'owner' past EVERYTHING
}
```

Replace With This:

```
public function handle(Request $request, Closure $next, string $permission): Response
{
    $user = Auth::user();

    // Platform routes: only is_platform_admin = true gets through
    // Everyone else gets 404 – not 403, not a redirect – 404
    if ($request->routeIs('admin.*')) {
        if (!$user->is_platform_admin) { abort(404); }
        return $next($request);
    }

    // Store routes: check the permission against their role in this store
    $membership = app()->bound('current.membership') ? app('current.membership') : null;
    if (!$membership) { return redirect()->route('hub'); }

    $map = config('permissions');
    if (!in_array($permission, $map[$membership->role] ?? [])) {
        abort(403, 'You do not have permission to access this area.');
```

```
    }

    return $next($request);
}
```

Also do this in your database right now:

```
-- Set yourself as platform admin (do this once, manually in database)
UPDATE users SET is_platform_admin = 1 WHERE email = 'your@email.com';

-- Confirm no store user has is_platform_admin set
SELECT email, is_platform_admin FROM users WHERE is_platform_admin = 1;

-- Should show only your email
```

- **is_platform_admin = 1 set on your account only**
- **No other user has is_platform_admin = 1**
- **The owner/admin God Mode bypass line is deleted from CheckPermissions.php**

2

Create config/permissions.php

One clean file that defines exactly what each store role can do

Create this file at config/permissions.php. This becomes the single source of truth for all store-level permissions. No more checking role strings scattered across controllers.

Role	What they can do	What they cannot do
owner	Everything in the store: POS, inventory, sales, purchases, finance, reports, staff, settings, billing	Nothing — they own the store. Billing is store-level only, never platform.
admin	Everything except billing management, store deletion, and ownership transfer	Cannot touch billing or delete the store
manager	All operational features: POS, sales, purchases, inventory, all 38 reports. Cannot manage staff.	No staff management, no settings, no billing
cashier	POS only. Can see stock levels. Can add a customer at the register.	Cannot see any financial data, staff info, or reports
accountant	All financial reports and accounting. Read-only on sales/purchases.	Cannot create sales, cannot access POS, cannot manage staff
purchasing_officer	Purchase orders, supplier management, inventory view	Cannot see sales, customers, or financial reports
viewer	Read-only access to reports and finance view	Cannot create or change anything — zero write access

```
Route::get('/staff', [StaffController::class, 'index'])->middleware('permissions:staff.index');
Route::post('/staff/invite', [StaffController::class, 'invite'])->middleware('permissions:staff.invite');
```

3

Fix routes/web.phpMove ALL legacy routes inside the `s/{store_slug}` tenant wrapper

Routes like `/reports`, `/inventory`, `/pos`, `/settings` exist as bare global URLs without `TenantMiddleware`. Every single one of them must move into the `Zone 3` wrapper.

The Four Zones — Every Route Belongs to Exactly One Zone:

ZONE 1 — Public	No auth needed
<code>/</code> <code>/pricing</code> <code>/terms</code> <code>/privacy</code> <code>/webhooks/lemon-squeezy</code>	
ZONE 2 — Auth, No Store	Logged in but no store context yet
<code>/hub</code> <code>/start</code> <code>/new-store</code> <code>/join</code> <code>/invite/{token}</code> <code>/redeem</code> <code>/account</code> <code>/logout</code>	
ZONE 3 — Store World	Auth + valid store membership + TenantMiddleware — ALL legacy routes move here
<code>/s/{store_slug}/dashboard</code> <code>/s/{store_slug}/pos/*</code> <code>/s/{store_slug}/inventory/*</code> <code>/s/{store_slug}/sales/*</code> <code>/s/{store_slug}/purchases/*</code> <code>/s/{store_slug}/finance/*</code> <code>/s/{store_slug}/reports/*</code> <code>/s/{store_slug}/staff/*</code> <code>/s/{store_slug}/settings/*</code> <code>/s/{store_slug}/billing/*</code>	
ZONE 4 — Platform HQ	SuperAdminMiddleware — 404 for everyone else
<code>/VenQore/dashboard</code> <code>/VenQore/stores</code> <code>/VenQore/users</code> <code>/VenQore/revenue</code>	

...

```
// The Zone 3 wrapper – ALL store routes go inside this group
Route::middleware(['auth', 'verified', 'tenant'])
->prefix('s/{store_slug}')
->name('store.')
->group(function () {
Route::get('/dashboard', [DashboardController::class, 'index'])->name('dashboard');
// Every old /reports route becomes /s/{store_slug}/reports
Route::prefix('reports')->name('reports.')->group(function () {
Route::get('/', [ReportController::class, 'index'])
->middleware('permission:reports.view')->name('index');
// ... all 38 reports same pattern
});
// Every old /inventory route becomes /s/{store_slug}/inventory
Route::prefix('inventory')->name('inventory.')->group(function () {
Route::get('/', [InventoryController::class, 'index'])
->middleware('permission:inventory.view')->name('index');
// ... same pattern
});
// ... same for pos, sales, purchases, finance, staff, settings, billing
});
// Fallback – any URL not matched above returns 404
Route::fallback(fn() => abort(404));
```

4

Fix SuperAdminMiddleware.php

404 for non-platform-admin — never 403, never redirect

A 403 response says 'this page exists but you are not allowed.' That tells you you're investigating. A 404 says 'this page does not exist.' Store owners who get 404s will not investigate. No redirect.

```
// app/Http/Middleware/SuperAdminMiddleware.php

public function handle(Request $request, Closure $next): Response
{
    $user = Auth::user();

    // Not logged in: 404 (not redirect to login — that reveals the route exists)
    if (!$user) { abort(404); }

    // Logged in but not platform admin: 404
    if (!$user->is_platform_admin) { abort(404); }

    return $next($request);
}
```

5

Fix OneGlanceLayout.jsx

The frontend must never know platform routes exist for store users

The current code says: if the store prop is null or undefined, show Platform links. This should mean: go back to /hub to pick a store. Platform links should never be shown.

Remove This Pattern Completely:

```
// BROKEN — REMOVE THIS
const menuItems = (!store || userRole === 'platform_admin') ? [
  { name: 'Admin Home', route: 'admin.home' }, // ← Platform links in store layout!
  { name: 'Dashboard', route: 'admin.dashboard' }, // ← Should never be here
] : [
  { name: 'Dashboard', route: 'store.dashboard' },
];
```

Replace With This:

```
// FIXED — store layout never references platform routes
const { store, my_role } = usePage().props;

// If no store context: redirect to hub immediately
// This is the ONLY fallback — never show platform links
if (!store) {
  window.location.href = '/hub';
  return null;
}

// Permission helper — checks against store role only
const permissionMap = {
  owner: ['inventory.view', 'sales.view', 'reports.view', 'staff.view', 'settings.view', 'billing.view'],
  admin: ['inventory.view', 'sales.view', 'reports.view', 'staff.view', 'settings.view'],
  manager: ['inventory.view', 'sales.view', 'reports.view'],
  cashier: ['inventory.view'],
  accountant: ['sales.view', 'finance.view', 'reports.view'],
  purchasing_officer: ['purchases.view', 'inventory.view'],
  viewer: ['reports.view'],
};

const can = (p) => permissionMap[my_role]?.includes(p) ?? false;

// Menu items — all routes stay inside /s/{store.slug}/
const menuItems = [
  { name: 'Dashboard', route: route('store.dashboard', {store_slug: store.slug}) },
  { name: 'POS', route: route('store.pos.index', {store_slug: store.slug}) },
  can('inventory.view') && { name: 'Inventory', route: route('store.inventory.index', {store_slug: store.slug}) },
  can('sales.view') && { name: 'Sales', route: route('store.sales.index', {store_slug: store.slug}) },
  can('reports.view') && { name: 'Reports', route: route('store.reports.index', {store_slug: store.slug}) },
  can('staff.view') && { name: 'Staff', route: route('store.staff.index', {store_slug: store.slug}) },
  can('settings.view') && { name: 'Settings', route: route('store.settings.index', {store_slug: store.slug}) },
];
```



```
can('billing.view') && { name: 'Billing', route: route('store.billing.index', {store_slug:
store.slug}) },
].filter(Boolean);
```

The button previously labelled 'Admin Panel' that pushed users to /admin now in the new structure there is no 'admin panel' concept — there is just the store admin at /s/{slug}/staff. The button that used to say 'Admin Panel' should now say 'Store Admin'.

6

Fix Store Owner Role Assignment

When a store is created, assign owner role correctly — never platform role

```
// app/Http/Controllers/StoreController.php – store creation

// After creating the tenant record:
TenantUser::create([
    'tenant_id' => $tenant->id,
    'user_id' => $user->id,
    'role' => 'owner', // ← Store owner role only
    'status' => 'active',
    'joined_at' => now(),
]);

// NEVER set is_platform_admin here
// is_platform_admin is ONLY set manually in the database for you
// A store owner creating a store is NOT a platform admin

// Verify after creation:
// SELECT is_platform_admin FROM users WHERE id = {new_user_id};
// Must return: 0
```

7

Fix SetupController.php

Wizard sets store settings only — never touches platform or permissions

```
// app/Http/Controllers/SetupController.php – wizard completion

public function complete(Request $request, string $store_slug): RedirectResponse
{
    $tenant = app('current.tenant');
    $membership = app('current.membership');

    $tenant->update([
        'name' => $request->input('business_name'),
        'currency_code' => $request->input('currency_code'),
        'currency_symbol' => $request->input('currency_symbol'),
        'timezone' => $request->input('timezone'),
        'industry' => $request->input('industry'),
        'setup_completed' => true,
    ]);

    // Industry feature flags
    $industry = $request->input('industry');
    $tenant->update([
        'feature_variants' => in_array($industry, ['fashion', 'apparel']),
        'feature_serials' => in_array($industry, ['electronics', 'it', 'mobile']),
        'feature_batches' => in_array($industry, ['pharmacy', 'medical']),
        'feature_manufacturing' => in_array($industry, ['bakery', 'factory']),
    ]);

    // Redirect stays inside the store – never goes to platform
    return redirect()->route('store.dashboard', ['store_slug' => $store_slug]);
}
```

8

Create a Separate Platform Login

The regular /login is for store users only. Your platform has its own hidden login.

Right now there is one /login page for everyone. You should have a com not linked anywhere on the public site. Store users use /login. You use / platform URL, they cannot log in there because the platform login rejects

```
// routes/web.php – add this

// Platform login – separate URL, not linked anywhere public
Route::middleware('guest')->group(function () {
Route::get('/VenQore-login', [PlatformLoginController::class, 'create'])
->name('platform.login');
Route::post('/VenQore-login', [PlatformLoginController::class, 'store'])
->middleware('throttle:5,1'); // 5 attempts per minute max
});

// PlatformLoginController::store()
public function store(LoginRequest $request): RedirectResponse
{
$request->authenticate();
$user = Auth::user();

if (!$user->is_platform_admin) {
Auth::logout();
return back()->withErrors(['email' => 'Invalid credentials.']);
// Generic error – does not reveal whether account exists
}

$request->session()->regenerate();
return redirect()->route('admin.dashboard');
}
```



Execution Order — Do These In This Exact Sequence

Execute steps top to bottom — do not skip any item

- **Set `is_platform_admin = 1` for your account in the database**
- Confirm no other user has `is_platform_admin = 1`
- **Delete the owner/admin God Mode bypass from `CheckPermissions.php`**
- Create `config/permissions.php` with the role permission map
- **Move ALL legacy routes (`/reports`, `/inventory`, `/pos`, etc.) into Zone 3 (`/s/{store_slug}`)**
- Add `Route::fallback(fn() => abort(404))` at the end of `routes/web.php`
- **Rewrite `SuperAdminMiddleware.php` to return 404 for non-platform-admin**
- **Fix `OneGlanceLayout.jsx` — remove platform links, add null-store redirect to `/hub`**
- **Remove the 'Admin Panel' button that went to `/admin-panel`**
- Fix `StoreController.php` — confirm owner `TenantUser` record is created correctly
- Fix `SetupController.php` — wizard never touches platform role or `is_platform_admin`
- Add `/VenQore-login` as a separate platform login route
- Run: `php artisan route:list | grep -v store | grep -v admin` — must return only public/auth routes
- **TEST: Log in as a store owner. Try to navigate to `/VenQore/dashboard` — must see 404**
- **TEST: Log in as a store owner. Click 'Admin Panel' or 'Settings' — must go to `/s/{slug}/settings`**
- **TEST: Log in as a store owner. Visit `/reports` — must get 404 (route no longer exists bare)**
- **TEST: Log in as a cashier. Visit `/s/{slug}/reports` — must get 403 (within store context)**
- TEST: Log in as a cashier. Visit `/s/{slug}/staff` — must get 403
- **TEST: Log in via `/VenQore-login` as yourself — must reach `/VenQore/dashboard`**
- **TEST: Create two stores, check data isolation still working after route changes**

After This Fix — The Mental Model

Who	What they do	What they see	What they cannot see or reach
Store Owner	Signs up, creates store, manages everything inside it	<code>/s/my-store/*</code> with full owner permissions	Any <code>/VenQore/*</code> URL (gets 404). Any other store's data. Platform login page.
Store Cashier	Operates POS only	<code>/s/my-store/dashboard</code> and <code>/s/my-store/pos</code> only	Reports, staff, settings, finance (all get 403 within store context)
You (Platform Admin)	Manages all stores, billing, users	<code>/VenQore/*</code> via <code>/VenQore-login</code>	Nothing is hidden from you — but you access it separately, not via <code>/login</code>

Anyone guessing URLs	Tries /VenQore/dashboard, /admin-panel, etc.	404 — page does not exist	No hint that the platform layer exists at all
----------------------	--	---------------------------	---